SIZMA TESTİ RAPORU

Rapor Tarihi	14/08/2026
Hazırlayan	Ömer Faruk Baysal
Test Türü	PortSwigger Web Academy Lab

1. Blind SQL injection with conditional responses

Bu raporda PortSwigger Web Security Academy'de yer alan "Blind SQL injection with conditional responses" labı ele alınmıştır.

2. Yönetici Özeti

Yapılan test sonucunda, analiz için takip çerezi kullandığı ve gönderilen çerezin değerini içeren bir SQL sorgusu gerçekleştirdiği tespit edilmiştir. Bu zafiyet, saldırganın uygulama ile ilgili çeşitli veriler ele geçirebilmesine olanak sağlayabilmektedir. Zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

İlgili hedef sitenin analiz için takip çerezi kullandığı ve gönderilen çerezin değerini içeren bir SQL sorgusu gerçekleştirdiği tespit edilmiştir. Sql sorgusunun sonuçları döndürelememkte olup hiçbir hata mesajı görünmemektedir fakat sorgunun herhangi bir satır döndürmesi durumunda uygulama sayfasında "Welcome back" mesajı tespit edilmektedir.

4. Risk Seviyesi

Risk Seviyesi	Kritik
CVSS v3.1 Skoru	9.8
CWE	CWE-89

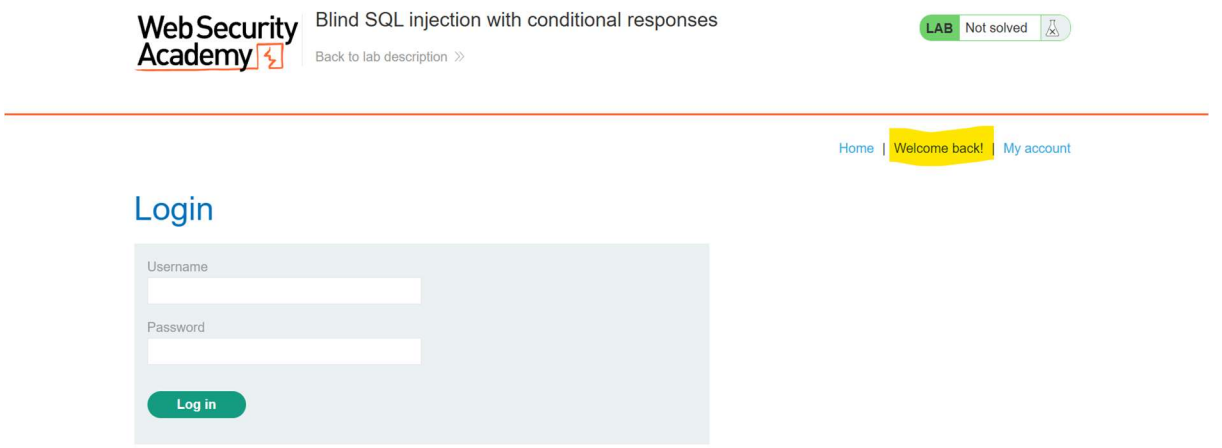
5. Etki

Bu zafiyet ile, sorgu sonuçları doğrudan görüntülenmese dahi, uygulamanın koşullu yanıtları (boolean tabanlı blind SQL injection) kullanılarak administrator kullanıcısının parolasının karakter karakter elde edildiği ve bu parolayla yönetici hesabına giriş yapıldığı kanıtlanmıştır. Aynı zafiyet, veritabanındaki tüm verilerin ele geçirilmesine ve kimlik doğrulamanın atlatılmasına ilerleyebilir.

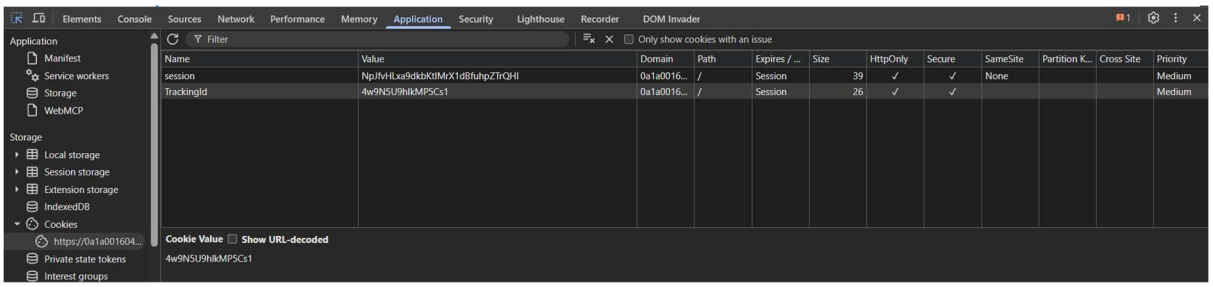
6. Proof Of Concept

Uygulama, analiz amacıyla bir takip çerezi kullanmaktadır ve bu çerezin değerini bir SQL sorgusuna dahil etmektedir. Sorgu sonucu doğrudan görüntülenmediğinden ve hata mesajı döndürülmediğinden, zafiyet kör (blind) niteliktedir. Ancak uygulama, sorgu bir satır döndürdüğünde sayfada "Welcome back" mesajı göstermektedir. Bu davranış farkı, koşullu (boolean tabanlı) bir yaklaşım ele alınacağının sinyali olmaktadır.

İlgili siteden “My account” kısmına erişildiğinde sağ üstte “Home” ve “My account” kısımlarının arasında “Welcome back!” yazdığı tespit edilecektir. Tespit edilen zafiyette çerezin değer içermesi halinde bu mesajı döndüreceği tespit edilmişti yani bu sayfada çalışan bir sorgu bulunmaktadır.

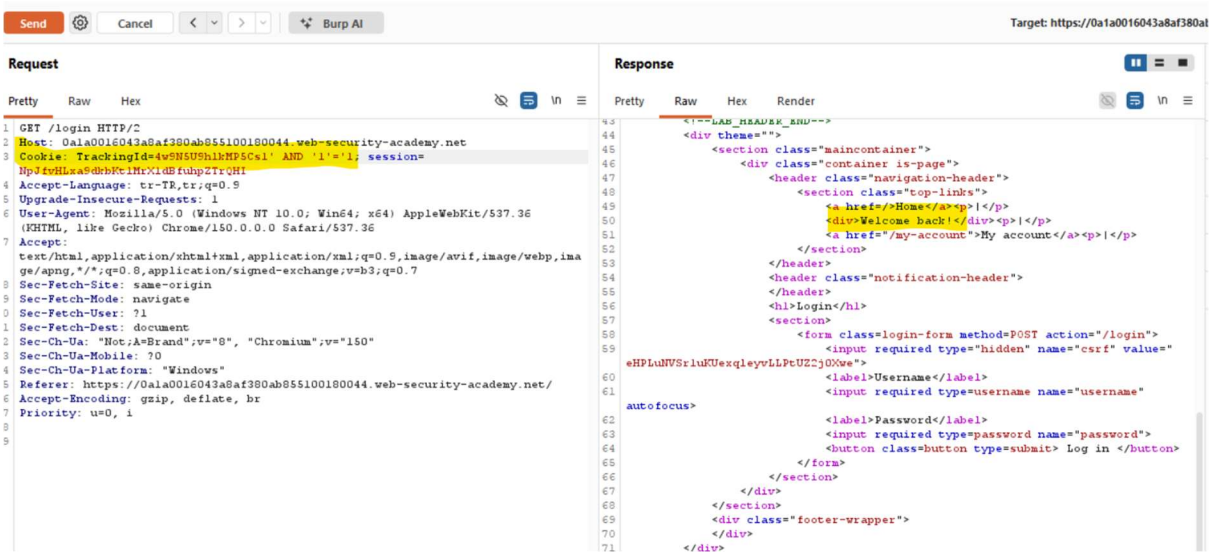


Tarayıcının dev tools’u açılıp “Application-> Cookies” kısmına tıklandığında 2 adet çerez ile karşılaşılacaktır.



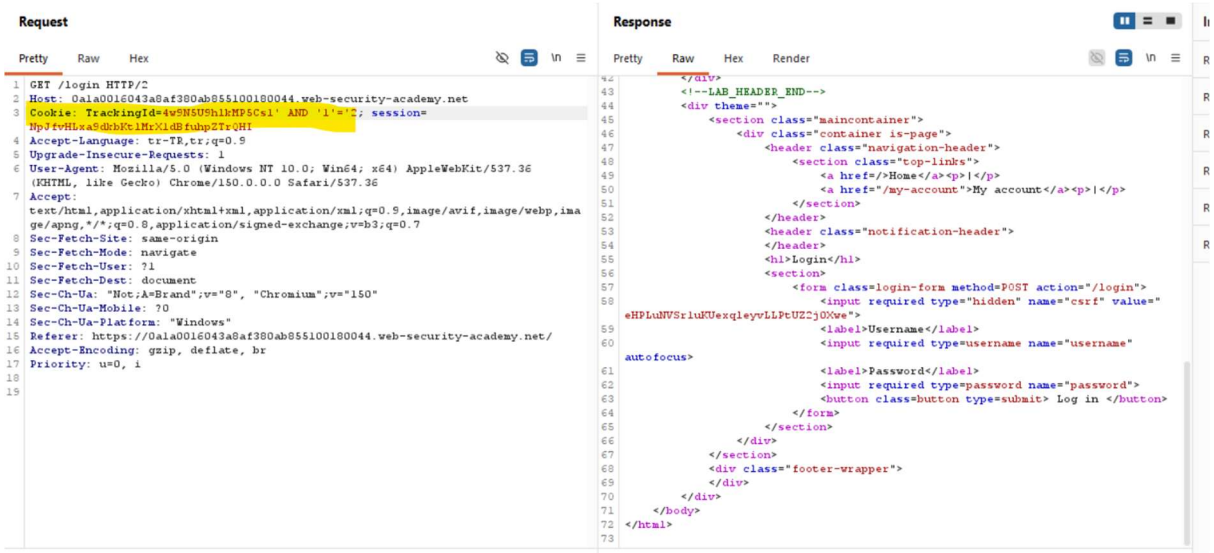
Burada yer alan “TrackingID” çerezinin isim benzerliğinden de kaynaklı analiz amaçlı kullanılan çerez olduğunun çıkarımına vardık. Bundan emin olmak için Burp Suite üzerinden Target kısmında yer alan login isteğini Burp Repeater’a göndererek burada “Cookie” değişkenine aşağıdaki payload enjekte edildiğinde “Welcome back” yazısının cevapta yer aldığı tespit edilecektir. Yani sorgu doğru dönünce mesaj da dönmektedir.

> TrackingId=4w9N5U9hlkMP5Cs1' AND '1'='1



Sorgu yanlış döndürülünce olan çıktıya bakmak için bu sefer payloadı değiştirirsek “Welcome back!” mesajıyla karşılaşmayacağızdır.

>TrackingId=4w9N5U9hlkMP5Cs1' AND '1'='2



İki koşulun (doğru/yanlış) farklı yanıtlar üretmesi, TrackingId çerez değerinin SQL sorgusuna güvenli olmayan biçimde dahil edildiğini ve koşullu kör (blind) SQL injection zafiyetinin bulunduğunu kanıtlamaktadır.

Bu tür zafiyetlerde, blind sql zafiyetlerinde, veri evet/hayır sorularıyla (boolean logic) kullanılarak elde edilmektedir. Bunun için şifre hakkında çeşitli denemeler TrackingID çerez değeri üzerinde yapılabilmektedir. Öncelikle şifrenin uzunluğunu yönelik deneme yapılır:

> TrackingId=4w9N5U9hlkMP5Cs1'AND (SELECT LENGTH(password) FROM users WHERE username='administrator')>1--;

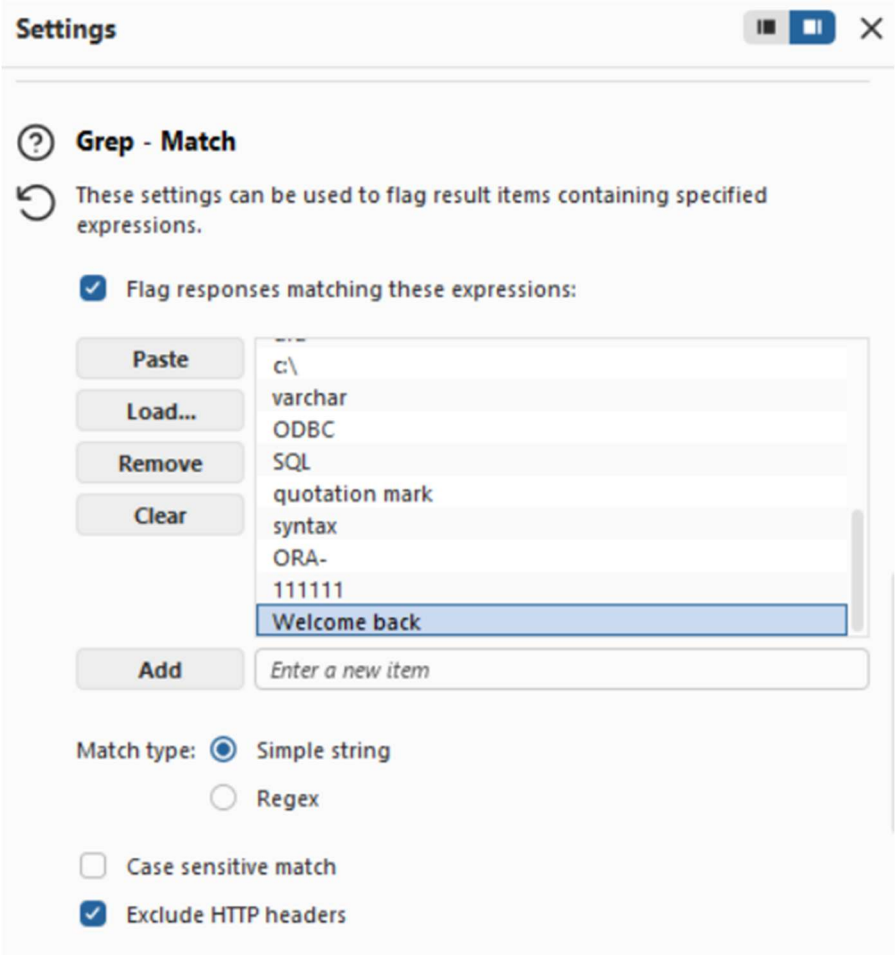
Bu payload ile administrator kullanıcısının şifre uzunluğu 1’den büyük mü diye sorduk ve cevapta da “Welcome back!” mesajı döndü. Mesaj döndüğüne göre bu soru doğrudur.



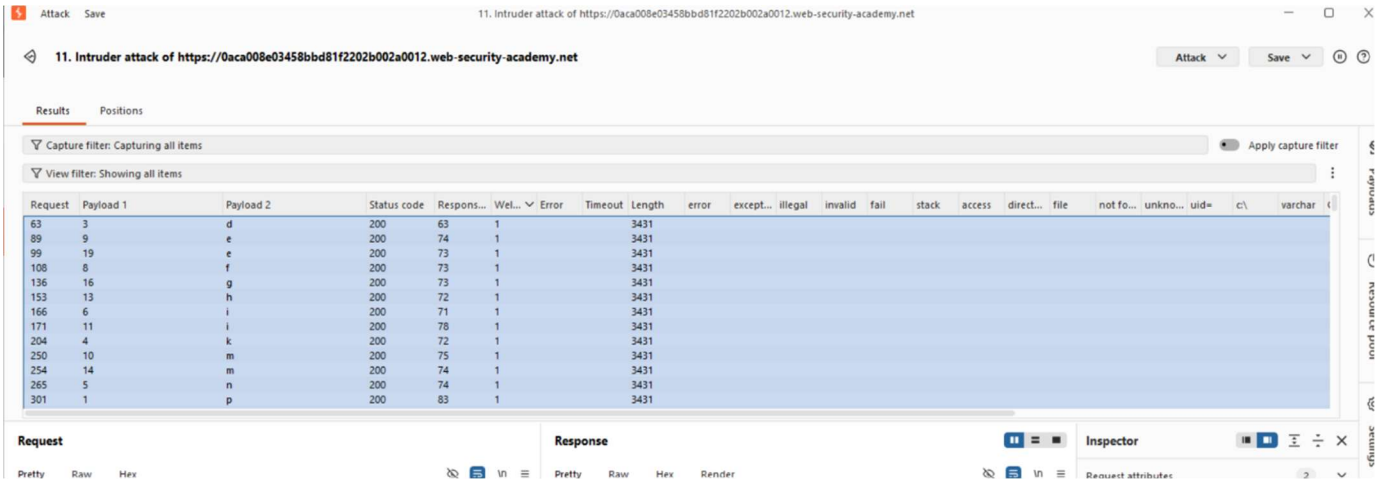
Sayıyı değişitirip denemeler yapılabilmektedir. Bu denemeler sonucunda “TrackingId=4w9N5U9hlkMP5Cs1'AND (SELECT LENGTH(password) FROM users WHERE username='administrator')>20--;” payloadından sonra mesaj döndürülez. Yani şifre 20 karakterlidir.

Karakter karakter deneme yapmak uzun olacağı için ilgili isteği Burp Intruder aracında ele alırız ve aşağıdaki payload ile denemeler yapılır:

>TrackingId=4w9N5U9hlkMP5Cs1' AND (SELECT SUBSTRING(password,1,1) FROM users WHERE username='administrator')='a'--



Ayarlardan Grep-Match kısmında aradığımız mesaj olan “Welcome back”i ekledik. Böylelikle bu mesajı içeren denemeleri daha kolay fark edebileceğiz.



Eşleşen sonuçlar Welcome back sütununda 1 ile döndürülüyor. Payload 1 sütunu, ilgili harfin kaçıncı sırada olduğunu belirtirken payload 2 sütunu da bu kısma denk gelen harfi temsil ediyor.
Uzun süren bu işlemi bekledikten sonra eşleştirmeler yapılır:

Pozisyon	**Harf**
1	p
2	r
3	d
4	k
5	n
6	i
7	p
8	f
9	e
10	m
11	i
12	w
13	h
14	m
15	q
16	g
17	z
18	r
19	e
20	u

Harfleri sırayla birleştirince şifre "***prdknipfemiwhmqgzreu***" olacaktır.
Kullanıcı adı *administrator* ve bulduğumuz şifre ile admin kullanıcısının hesabına erişilecektir.

7. Çözüm Önerisi

Parametrik sorgular kullanılmalıdır. Kullanıcı girdisi, SQL sorgusuna doğrudan string olarak birleştirilmemelidir. Bunun yerine, sorgu yapısı ile kullanıcı verisini ayrı işleyen parametrik sorgular kullanılmalıdır. Bu sayede kullanıcı girdisi, SQL kodu olarak değil yalnızca veri olarak yorumlanır ve zafiyet kökten önlenir.

Cookie gibi kullanıcı kontrollü değerler dahil tüm girdiler, beklenen türe ve formata göre doğrulanmalıdır. Beklenmeyen karakterler (SQL metakarakterleri, tırnak vb.) reddedilmelidir.

Uygulamanın kullandığı veritabanı hesabına yalnızca ihtiyaç duyduğu minimum yetkiler verilmelidir. Böylece olası bir injection durumunda etkinin (veri sızıntısı, komut çalıştırma) kapsamı sınırlandırılmalıdır.

8.Sonuç

Testin sonucunda hedefin sql enjeksiyonuna açık olduğu ve blind SQL injection ile administrator parolasının ele geçirilip yönetici hesabına giriş yapılabildiği doğrulanmıştır. Zafiyet kritik seviyede olup ivedilikle giderilmelidir.

SIZMA TESTİ RAPORU

Rapor Tarihi	17/08/2026
Hazırlayan	Ömer Faruk Baysal
Test Türü	PortSwigger Web Academy Lab

1. Blind SQL injection with time delays

Bu raporda PortSwigger Web Security Academy'de yer alan "Blind SQL injection with time delays" labı ele alınmıştır.

2. Yönetici Özeti

Yapılan test sonucunda, hedef uygulamanın analitik amaçla kullandığı takip çerezinin değerini bir SQL sorgusuna dahil ettiği ve bu noktada kör (blind) SQL injection zafiyeti bulunduğu tespit edilmiştir. Uygulama, sorgu sonucuna göre yanıtında herhangi bir farklılık göstermediğinden, zafiyet zaman tabanlı (time-based) bir teknikle doğrulanmıştır. Zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Hedef uygulama, analitik amacıyla bir takip çerezi kullanmakta ve bu çerezin değerini bir SQL sorgusuna doğrulamadan dahil etmektedir. Sorgu sonuçları yanıtta döndürülmemekte, hata mesajı görüntülenmemekte ve uygulama sorgunun sonucuna (satır dönmesi veya hata oluşması) göre farklı bir davranış sergilememektedir. Bu nedenle, koşullu yanıt (boolean) tabanlı bir çıkarım mümkün değildir. Ancak sorgu eşzamanlı (synchronous) çalıştığından, çerez değerine enjekte edilen koşullu bir zaman gecikmesi komutu ile yanıt süresi manipüle edilebilmektedir. Bu durum, zaman tabanlı (time-based) kör SQL injection zafiyetine işaret etmektedir.

4. Risk Seviyesi

Risk Seviyesi	Yüksek
CVSS v3.1 Skoru	7.5
CWE	CWE-89

5. Etki

Bu zafiyet ile, uygulamanın yanıtında herhangi bir görsel/içeriksel farklılık olmamasına rağmen, enjekte edilen komutla yanıt süresinin (yaklaşık 10 saniye) kontrol edilebildiği ve dolayısıyla SQL sorgusuna müdahale edilebildiği kanıtlanmıştır. Zaman tabanlı çıkarım, bir çıkarım kanalı olarak kullanılarak; uygulamanın yetki seviyesine ve veritabanı yapılandırmasına bağlı olarak veritabanındaki hassas verilerin (kullanıcı bilgileri, parolalar vb.) karakter karakter elde edilmesine, kimlik doğrulamanın atlatılmasına ve bazı durumlarda sistemde komut çalıştırılmasına kadar ilerleyebilir.

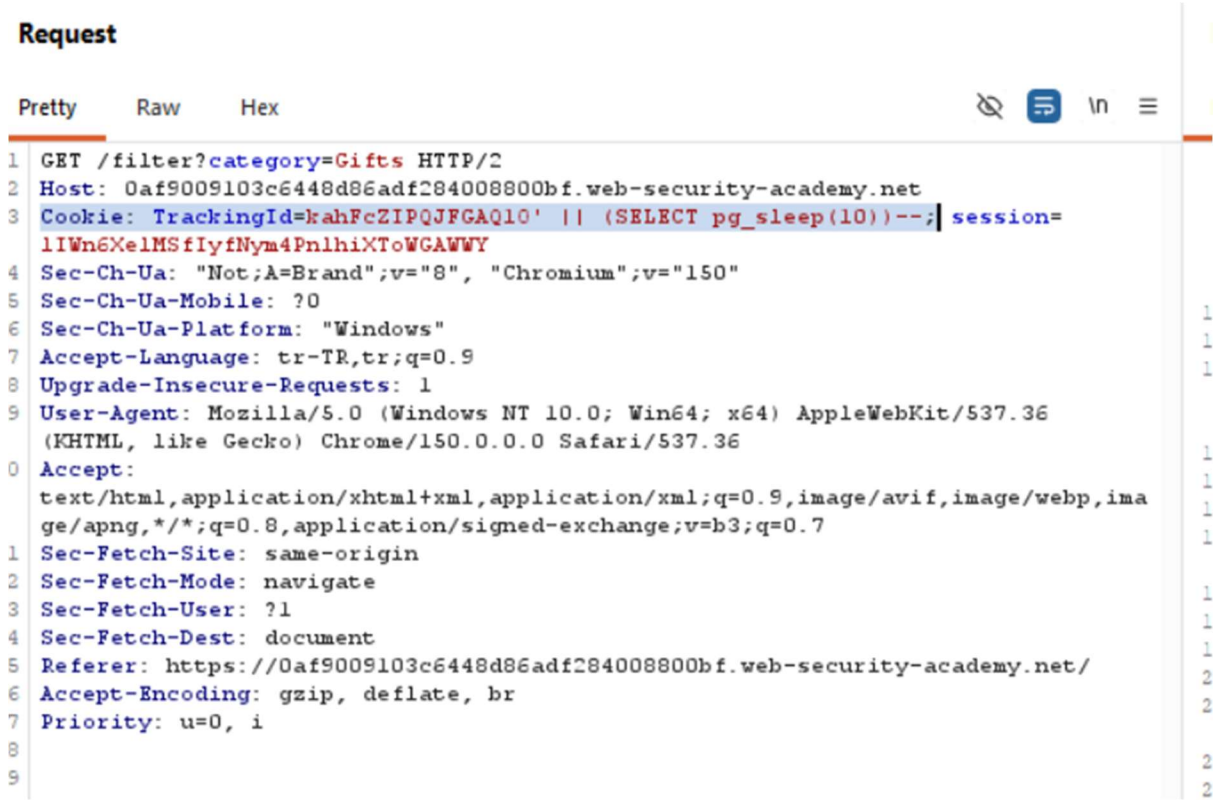
6. Proof Of Concept

Uygulama, analiz amacıyla bir takip çerezi kullanmaktadır ve bu çerezin değerini bir SQL sorgusuna dahil etmektedir. Sorgu sonuçları yanıtta döndürülmemekte, hata mesajı görüntülenmemekte ve uygulama sorgunun sonucuna (satır dönmesi veya hata oluşması) göre farklı bir davranış sergilememektedir. Bu nedenle, koşullu yanıt (boolean) tabanlı bir çıkarım mümkün değildir. Ancak sorgu eşzamanlı (synchronous) çalıştığından, çerez değerine enjekte edilen koşullu bir zaman gecikmesi komutu ile yanıt süresi manipüle edilebilmektedir. Bu durum, zaman tabanlı (time-based) kör SQL injection zafiyetine işaret etmektedir.

Ana sayfada bizi ürünler ve kategoriler karşılayacaktır. Test amaçlı bir kategori seçelim. Gifts kategorisini seçip isteği Burp Repeater'a yollayalım. Burada Cooike kısmında değişiklik yapılacaktır. Aşağıdaki payloadı denersek:

>TrackingId=kahFcZIPQJFGAQ1O || (SELECT pg_sleep(10))--

Bu payload, PostgreSql veritabanı için sleep(10) komutunu, 10 saniyelik delay komutunu, göndermektedir. Burada hangi veritabanını kullanıldığını bilmediğimiz için deneme-yanılma yöntemindan başka çare yoktur. Şanstır ki, ilk denemede 10 saniye süren bir delay gözlemlenir. Böylelikle hem veritabanını doğru tespit edilir hem de zafiyet ispatlanmaktadır.



7. Çözüm Önerisi

Parametrik sorgular kullanılmalıdır. Kullanıcı girdisi, SQL sorgusuna doğrudan string olarak birleştirilmemelidir. Bunun yerine, sorgu yapısı ile kullanıcı verisini ayrı işleyen parametrik sorgular kullanılmalıdır. Bu sayede kullanıcı girdisi, SQL kodu olarak değil yalnızca veri olarak yorumlanır ve zafiyet kökten önlenir.

Cookie gibi kullanıcı kontrollü değerler dahil tüm girdiler, beklenen türe ve formata göre doğrulanmalıdır. Beklenmeyen karakterler (SQL metakarakterleri, tırnak vb.) reddedilmelidir.

Uygulamanın kullandığı veritabanı hesabına yalnızca ihtiyaç duyduğu minimum yetkiler verilmelidir. Böylece olası bir injection durumunda etkinin (veri sızıntısı, komut çalıştırma) kapsamı sınırlandırılmalıdır.

8.Sonuç

Testin sonucunda hedefin sql enjeksiyonuna açık olduğu tespit edilmiştir. Zafiyet, yüksek seviyede olup ivedilikle giderilmelidir.
